

CNO V: Seguridad Informática



Alumna:

Tristan Rivera Magdalena Yesenia - 174702

Profesor:

Mtro. Servando López Contreras

Fecha: -----

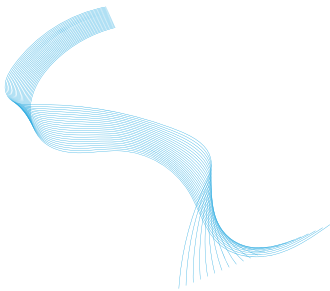
Practica: ACTIVIDAD 02 -

Análisis de servicios de seguridad

(X.800 y RFC 4949)

Grupo:T46B

Horario: 20:00 - 21:00



Análisis de Servicios de Seguridad (X.800 y RFC 4949)

1. Introducción

El presente análisis examina distintos escenarios de incidentes de seguridad informática aplicando los seis servicios de seguridad definidos en el modelo X.800 (autenticación, control de acceso, confidencialidad, integridad, no repudio y disponibilidad), así como la terminología formal establecida en el RFC 4949.

Mientras X.800 proporciona una arquitectura conceptual que define **qué servicio de seguridad ha sido comprometido**, el RFC 4949 ofrece el **lenguaje técnico estandarizado** para describir con precisión amenazas, vulnerabilidades, ataques e impactos. La integración de ambos marcos permite una documentación profesional y técnicamente fundamentada.

2. Marco Teórico

2.1 Servicios de Seguridad – X.800

El modelo X.800 establece seis servicios fundamentales:

- **Autenticación**
- **Control de acceso**
- **Confidencialidad**
- **Integridad**
- **No repudio**
- **Disponibilidad**

Estos servicios constituyen la base estructural para evaluar incidentes desde una perspectiva arquitectónica.

2.2 Terminología Formal – RFC 4949

El RFC 4949 define formalmente conceptos esenciales. Por ejemplo:

- **Attack:** "An assault on system security that derives from an intelligent threat."
- **Vulnerability:** "A flaw or weakness in a system's design, implementation, or operation and management that could be exploited."
- **Data breach:** "The disclosure of information to unauthorized parties."
- **Availability:** "The property of a system or system resource being accessible and usable upon demand."

Estas definiciones permiten describir técnicamente cada escenario con precisión conceptual.

3. Análisis de Escenarios

ESCENARIO 01 – Ransomware Multi-Stage (LockBit)

Servicios X.800 comprometidos:

Confidencialidad, Integridad y Disponibilidad.

Definiciones aplicables RFC 4949:

- **Multi-stage attack**
- **Data breach**
- **Availability attack**

Cita textual:

“A multi-stage attack is one that uses multiple steps or phases to achieve its objective.”

El incidente inicia con acceso no autorizado, continúa con exfiltración de información (data breach) y culmina con cifrado masivo (availability attack). La indisponibilidad es la fase final, pero no el único impacto.

Tipo de amenaza:

Externa organizada y persistente.

Impacto:

Compromiso total del entorno tecnológico y paralización operativa.

Medidas de control:

Backups inmutables, segmentación de red, monitoreo continuo, modelo Zero Trust.

ESCENARIO 02 – Exposición por mala configuración

Servicios comprometidos:

Confidencialidad.

Definiciones RFC 4949:

- **Misconfiguration**
- **Exposure**

Cita textual:

“Exposure: A state in which information is accessible to unauthorized entities.”

No existe explotación activa; la vulnerabilidad surge de una mala configuración del control de acceso.

Impacto:

Consecuencias legales y reputacionales.

Medidas:

Hardening, auditorías periódicas, principio de mínimo privilegio.

ESCENARIO 03 – Supply Chain Attack

Servicios comprometidos:

Integridad y Confidencialidad.

Definición RFC 4949:

- **Supply chain attack**

Este ataque vulnera la confianza depositada en un proveedor legítimo, comprometiendo la integridad del software distribuido.

Impacto:

Compromiso masivo de múltiples organizaciones.

Medidas:

Verificación criptográfica avanzada y monitoreo independiente.

ESCENARIO 04 – Credential Compromise por phishing

Servicios comprometidos:

Autenticación, Control de acceso, Confidencialidad.

Definiciones RFC 4949:

- **Phishing**
- **Credential compromise**

Cita textual:

“Phishing: A technique for attempting to acquire sensitive data by masquerading as a trustworthy entity.”

Aunque el sistema autentica correctamente las credenciales, existe una falla conceptual porque la identidad legítima ha sido suplantada.

Medidas:

MFA obligatorio y monitoreo de comportamiento.

ESCENARIO 05 – Eliminación de respaldos

Servicios comprometidos:

Disponibilidad e Integridad.

Definiciones:

- **Data destruction**
- **Availability attack**

El ataque busca impedir cualquier recuperación operativa, maximizando el daño.

Medidas:

Backups offline e inmutables.

ESCENARIO 06 – Insider Threat

Servicios comprometidos:

Confidencialidad y Control de acceso.

Definición:

“Insider threat: A security threat that originates from within the organization.”

El abuso de privilegios legítimos evidencia fallas en la aplicación del principio de mínimo privilegio.

ESCENARIO 07 – Alteración de registros

Servicios comprometidos:

Integridad y No repudio.

Definiciones:

- **Audit trail**
- **Evidentiary integrity**

La alteración de logs impide reconstruir eventos y afecta la validez probatoria.

ESCENARIO 08 – Falla operacional

Servicio comprometido:

Disponibilidad.

Definición:

- **Operational failure**

Demuestra que la seguridad no solo depende de ataques maliciosos, sino también de la gestión interna.

ESCENARIO 09 – Masquerade y phishing institucional

Servicios comprometidos:

Autenticación y Confidencialidad.

Definición:

“Masquerade: A type of attack in which one entity pretends to be a different entity.”

El componente de ingeniería social facilita la obtención de información sensible.

ESCENARIO 10 – Ataque destructivo total

Servicios comprometidos:

Confidencialidad, Integridad y Disponibilidad.

Definición:

- **Destructive attack**

Este escenario representa el máximo nivel de impacto, combinando exfiltración y destrucción irreversible.

4. Conclusión Comparativa

El modelo X.800 permite identificar qué dimensión de la seguridad ha sido vulnerada, mientras que el RFC 4949 proporciona el marco terminológico preciso para describir la naturaleza técnica del incidente.

Su complementariedad fortalece:

- La documentación profesional.
- La comunicación técnica.
- El análisis estructurado de incidentes.
- La argumentación académica.

La correcta aplicación de ambos marcos demuestra madurez conceptual y capacidad para realizar análisis técnicos fundamentados en estándares internacionales.